

Botium Toys — Case Study Background

■ PROVIDED SCENARIO MATERIAL — This document is the background case study supplied as part of the Google Cybersecurity Certificate capstone project. It is not original analysis; it is included here for context so the accompanying Controls and Compliance Checklist (my own completed work) can be understood on its own.

Scope, Goals, and Risk Assessment Audit Report

Scope

The scope of this audit encompasses the entire IT infrastructure and security program at Botium Toys. It includes the assessment of all assets, internal processes, and procedures related to the implementation of controls and compliance best practices.

Goals

The primary goals of this audit are to assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices need to be implemented to enhance Botium Toys' security posture.

Current Assets

- On-premises equipment for in-office business needs
- Employee equipment: desktops, laptops, smartphones, remote workstations, headsets, cables, keyboards, mice, docking stations, surveillance cameras, etc.
- Storefront products for retail sale on-site and online, stored in the adjoining warehouse
- Management of systems, software, and services: accounting, telecommunication, database, security, e-commerce, and inventory management
- Internet access
- Internal network
- Data retention and storage
- Legacy system maintenance (end-of-life systems requiring human monitoring)

Risk Assessment

Risk Description

There is currently inadequate management of assets at Botium Toys, and the organization does not have all necessary controls in place. This may result in non-compliance with U.S. and international regulations and standards.

Risk Score: 8 / 10

A fairly high level of risk, attributed to the absence of controls and non-compliance with best practices related to data security and privacy.

Key Findings

- **Access to data:** All employees currently have access to internally stored data, including cardholder data and customer PII/SPII.
- **Encryption:** Not used to protect customers' credit card information, which is processed and stored locally.

- **Access controls:** Least privilege and separation of duties have not been implemented.
- **Data integrity:** The IT department has ensured data availability and integrated controls to maintain integrity.
- **Firewall:** In place and blocks traffic based on defined security rules.
- **Antivirus:** Installed and regularly monitored.
- **IDS:** Not installed.
- **Disaster recovery:** No plans in place; no backups of critical data.
- **Breach notification:** A 72-hour E.U. customer notification plan is established; privacy policies are developed and enforced.
- **Password policy:** Exists, but minimal and outdated (does not enforce 8+ characters, numbers, special characters).
- **Password management:** No centralized system to enforce policy requirements.
- **Legacy systems:** Monitored but with no regular schedule or clear intervention methods.
- **Physical security:** Sufficient locks, up-to-date CCTV, and functioning fire detection/prevention are in place.

Conclusion

This audit identified substantial risk in Botium Toys' current security program, primarily due to the absence of proper controls and non-compliance with established best practices. Immediate steps are needed to address these deficiencies. Further detail is available in the accompanying Controls and Compliance Checklist.